ASSESSMENT ~~TOOL I~~ MCQ

COURSE CODE: ITA14 COURSE NAME: Ethical Hacking

Name	P Venkata Sai Pradeep Reddy
Register Number	192311364
Date	8 October 2026

COURSE OUTCOME COVERED

CO1: Apply the principle of the foundational concepts of ethical hacking, includingtypes of hackers, ethical principles, legal frameworks, and the role of responsibledisclosure in cybersecurity.

Assessment Tool Weightage: 40%

Duration: 50 min Total Marks: 50

MCQ Questions

1. A company authorizes a security professional to test only its web server. During testing, the professional notices another vulnerable database server. What should the ethical hacker apply in this situation? A) Test the database immediately
B) Remain within the authorized scope and report the observation C) Exploit the database to verify the weakness
D) Download the database for analysis

Correct Answer: B

2. A security tester receives written permission to assess a company network. Which action should the tester perform first to apply ethical hacking principles?A) Launch vulnerability exploits
B) Review the authorized scope and rules of engagement C) Disable the firewall
D) Collect employee passwords

Correct Answer: B

3. An ethical hacker discovers confidential customer information duringanauthorized penetration test. How should the hacker apply confidentialityprinciples?
A) Copy the information to a personal device B) Share it with other testers outside the project
C) Protect the information and follow the agreed reporting procedureD) Publish the information as evidence

Correct Answer: C

4. A student wants to practice vulnerability scanning on the college network. How should ethical hacking principles be applied? A) Scan the network without informing anyone B) Obtain authorization before performing the scan C) Scan only during the night
D) Hide the source IP address

Correct Answer: B

5. During an authorized assessment, a tester identifies a critical vulnerability. Which action applies responsible disclosure correctly? A) Post the vulnerability publicly immediately B) Report it securely to the authorized organization C) Sell the information
D) Ignore the vulnerability

Correct Answer: B

6. A penetration tester is authorized to test IP addresses 192.168.1.10–192.168.1.20. Which target can the tester ethically assess?A) 192.168.1.5
B) 192.168.1.25
C) 192.168.1.15
D) 192.168.2.10

Correct Answer: C

7. A tester accidentally gains access to sensitive payroll records duringanassessment. What should the tester do?
A) Modify the records to demonstrate access
B) Download all records
C) Minimize further access and report the finding D) Share screenshots publicly

Correct Answer: C

8. A company asks an ethical hacker to assess its website without affectingnormal users. Which approach should the hacker apply?
A) Perform only approved, controlled, non-destructive testing B) Shut down the website
C) Delete vulnerable files
D) Modify customer accounts

Correct Answer: A

9. An employee discovers a security flaw in the organization’s internal application. How should proper disclosure be applied? A) Publish the flaw online
B) Report it through the organization's approved security channel C) Exploit the flaw repeatedly
D) Inform unrelated organizations

Correct Answer: B

10. A tester is given authorization that expires at 6:00 PM. At 6:15 PM, testingis incomplete. What should the tester do?

A) Continue until testing is finished
B) Stop testing and obtain renewed authorization before continuing C) Continue without recording the activity
D) Change the system time

Correct Answer: B

11. A security professional wants to demonstrate the impact of a vulnerability. Which action best applies ethical hacking practice? A) Cause maximum possible damage
B) Use the least harmful approved method to demonstrate the risk C) Delete system files
D) Publish confidential data

Correct Answer: B

12. A penetration tester discovers login credentials while performinganauthorized assessment. How should the credentials be handled? A) Store them publicly
B) Use them on unrelated systems
C) Protect them and use them only as permitted by the assessment scopeD) Share them with friends

Correct Answer: C

13. A company permits testing of its web application but specifically prohibitsdenial-of-service testing. Which action should the tester take? A) Perform denial-of-service testing anyway
B) Follow the restriction and avoid denial-of-service testing
C) Perform it outside office hours
D) Ask another person to perform it Correct Answer: B

14. An ethical hacker finds a vulnerability that could expose thousands of customer records. Which response correctly applies professional ethics?A) Download all customer records
B) Document the vulnerability while minimizing exposure of customer dataC) Publish sample customer records
D) Use the data for another project

Correct Answer: B

15. A tester realizes that a scanning tool is sending requests to systemsoutsidethe approved IP range. What should the tester do? A) Allow the scan to continue
B) Stop or reconfigure the scan to remain within scope C) Increase the scanning speed
D) Ignore the issue

Correct Answer: B

16. An organization hires a penetration tester to evaluate its network. Whichdocument should be applied to determine permitted and prohibited activities?A) Rules of engagement
B) Employee attendance record
C) Software installation guide
D) Marketing report

Correct Answer: A

17. A researcher discovers a vulnerability in a public website without prior authorization. What is the most appropriate ethical action? A) Exploit it to determine its full impact
B) Avoid unauthorized exploitation and use the site's approved vulnerability reporting process if available
C) Download user information
D) Change the vulnerable code

Correct Answer: B

18. During testing, an ethical hacker finds evidence of an unexpectedserioussecurity issue. What should the hacker do?
A) Ignore it because it was unexpected
B) Follow the agreed escalation and reporting procedure C) Delete the evidence
D) Publish the evidence immediately

Correct Answer: B

19. A penetration tester completes an assessment and has temporarycopiesofsensitive data collected under authorization. What should be done accordingtothe agreed data-handling policy?
A) Keep the data permanently
B) Transfer it to a personal computer
C) Securely retain or dispose of it according to the agreement D) Share it with students

Correct Answer: C

20. A tester needs to verify a vulnerability that could potentially crashaproduction server. Which action best applies ethical principles? A) Test it immediately on the production server
B) Follow the approved testing procedure and use a safe environment wherepossible
C) Crash the server intentionally
D) Ignore all organizational restrictions

Correct Answer: B

21. An ethical hacker is asked to test employee awareness using simulatedphishing. What should be established before conducting the exercise? A) Authorization, scope, and approved procedures B) Employees' personal passwords
C) Access to personal email accounts
D) Permission from unrelated companies

Correct Answer: A

22. A security tester discovers that the approved scope document containsunclear instructions about testing a particular server. What should thetester do?A) Assume permission is granted
B) Obtain clarification before testing that server
C) Attack the server anonymously
D) Test first and ask later

Correct Answer: B

23. During an authorized assessment, a tester identifies a weak passwordonan account.

Which action appropriately applies ethical hacking principles?A) Post the password online
B) Use it only as authorized and document the weakness C) Use it to access unrelated accounts
D) Give it to other employees
Correct Answer: B

24. A company asks a security professional to prepare a report after testing. Which information should be included to support ethical disclosure? A) Vulnerabilities, evidence, risk, and recommended remediation B) Personal opinions about employees
C) Unrelated customer information
D) Passwords for public distribution

Correct Answer: A

25. A security team plans an ethical hacking assessment. Which sequencebestapplies ethical hacking principles?
A) Exploit → Obtain permission → Report → Define scope B) Obtain authorization → Define scope → Test → Document →Report C) Scan → Publish → Obtain permission → Exploit D) Attack → Collect data → Share → Delete evidence

Correct Answer: B

25. A senior security researcher is hired to test a decentralized cryptocurrencyexchange. During the engagement, they notice a marketing team's standalone server is highly vulnerable. The tester decides to executearemote code execution payload to provide a more comprehensive report. Evaluate this decision from a legal and ethical standpoint.

A. It is ethically sound because it improves the client's overall securityposture.

B. It is valid under standard ethical hacking frameworks providednodataispermanently deleted.

C. It is legally protected as long as the tester does not monetize or leakthefindings.

D. It violates explicit authorization, risking severe legal liability andbreachingethical boundaries.

Correct Answer: D

26.While officially authorized to test a decentralized cryptocurrency exchange, An internal compliance auditor assumes the contract implicitly includes the building's physical security camera systemandproceeds to attack it. Judge the legal validity of this assumption.

A. Ethically and legally dangerous; authorization must always be explicit, documented, and unambiguous.

B. It is legally permissible as long as the actor is a certified and licensedprofessional.

C. It is standard practice to ensure no blind spots remain in the client'soverall audit.

D. It is a valid assumption if both systems share the same internal IPsubnet.

27. An independent ethical hacker is offered a contract to audit a federal tax web portal, but

they recently was rejected for a full-time role therelast week. Judge the decision to accept this auditing contract.

A. Unethical due to a severe conflict of interest that compromises theauditor's objectivity.

B. Legal and ethical, provided they sign a supplementary non-disclosureagreement.

C. Acceptable, as long as they only utilize automated scanning tools toremove bias.

D. Ethical, as their insider knowledge will result in a more thorough securitytest.

Correct Answer: A

28.Following an engagement against a multi-national bank's mobileapp, management strictly asks A corporate security consultant to deleteanymention of the CEO's compromised email account in the final official report. Recommend the most ethical response.

A. Alter the report as requested, but leave a hidden cryptographic signatureindicating tampering.

B. Refuse the request entirely to maintain the integrity, accuracy, andobjectivity of the audit.

C. Agree to the modification, but charge a premium fee for alteringofficial compliance documents.

D. Comply with the request, as the client owns the report and retains final editorial rights.

Correct Answer: B

29.Months after successfully finishing a penetration test on a decentralized cryptocurrency exchange, An internal compliance auditor decides to retain the database of unencrypted credit card transactionson a local home server 'just in case'. Critique this post-engagement practice.

A. It blatantly violates the ethical mandate for secure data destructionandstrict confidentiality.

B. It is ethically acceptable as long as the home server is disconnectedfromthe public internet.

C. It is a standard industry practice to retain client data for long-termhistorical benchmarking.

D. It is legally required to prove the vulnerabilities existed in case of afutureaudit dispute.

Correct Answer: A

30.A network security auditor is offered a contract to audit a logisticsand shipping API, but they recently is secretly building a competingsoftware product. Judge the decision to

accept this auditing contract.

A. Unethical due to a severe conflict of interest that compromises theauditor's objectivity.

B. Ethical, as their insider knowledge will result in a more thorough securitytest.

C. Legal and ethical, provided they sign a supplementary non-disclosureagreement.

D. Acceptable, as long as they only utilize automated scanning tools toremove bias.

Correct Answer: A

31. During a monitoring phase, A corporate security consultant detectsan active, malicious attack originating against an online retail platform. They immediately respond by deploying a reverse-shell to delete theattacker's tools. Judge this defensive response.

A. It is legally protected under international self-defense doctrines for digital property.

B. It is ethically mandated to prevent further harm to the client's networkinfrastructure.

C. It is acceptable if local law enforcement is notified within 24 hours of thecounter-attack.

D. It is illegal vigilantism (hacking back); ethical hacking does not authorize offensive actions against third parties.

Correct Answer: D

32. Months after successfully finishing a penetration test on a university'sresearch database, A bug bounty participant decides to retain the medical records accessed during the test on alocal home server 'just incase'. Critique this post-engagement practice.

A. It is legally required to prove the vulnerabilities existed in case of afutureaudit dispute.

B. It is ethically acceptable as long as the home server is disconnectedfromthe public internet.

C. It is a standard industry practice to retain client data for long-termhistorical benchmarking.

D. It blatantly violates the ethical mandate for secure data destructionandstrict confidentiality.

Correct Answer: D

33.While officially authorized to test a public transportation control system, A junior penetration tester assumes the contract implicitly includes a staging server that closely mirrors production and proceedstoattack it. Judge the legal validity of this assumption.

A. It is legally permissible as long as the actor is a certified and licensedprofessional.

B. Ethically and legally dangerous; authorization must always be explicit, documented, and unambiguous.

C. It is standard practice to ensure no blind spots remain in the client'soverall audit.

D. It is a valid assumption if both systems share the same internal IPsubnet. Correct

Answer: B

34.An internal compliance auditor is offered a contract to audit a regional hospital's network, but they recently has a lucrative side-deal withtheir top competitor to leak data. Judge the decision to accept this auditingcontract.

A. Ethical, as their insider knowledge will result in a more thorough securitytest.
B. Legal and ethical, provided they sign a supplementary non-disclosureagreement.
C. Acceptable, as long as they only utilize automated scanning tools toremove bias.
D. Unethical due to a severe conflict of interest that compromises theauditor's objectivity.

Correct Answer: D

35.A corporate security consultant identifies a vulnerability in an onlineretail platform without any prior permission and creates a video showingthe hack but hides the company name. Classify the hacker profile andevaluate the action.

A. Hacktivism; aimed at political reform by exposing the company's weaksecurity posture.
B. Black hat behavior; driven strictly by malicious intent and violationof theCIA triad.
C. Gray hat behavior; well-intentioned but legally perilous due to thestrict lack of authorization.
D. White hat behavior; entirely ethical and legal since the ultimate goal wassystem defense.

Correct Answer: C

36.An internal compliance auditor identifies a vulnerability in a regional hospital's network without any prior permission and fixes the flawbut leaves a harmless backdoor for themselves. Classify the hacker profileand evaluate the action.

A. White hat behavior; entirely ethical and legal since the ultimate goal wassystem defense.
B. Hacktivism; aimed at political reform by exposing the company's weaksecurity posture.
C. Gray hat behavior; well-intentioned but legally perilous due to thestrict lack of authorization.
D. Black hat behavior; driven strictly by malicious intent and violationof theCIA triad.

Correct Answer: D

37. During a monitoring phase, An independent ethical hacker detectsan active, malicious attack originating against a federal tax web portal. They immediately respond by wiping the attacker's database
of stolen credentials. Judge this defensive response.

A. It is illegal vigilantism (hacking back); ethical hacking does not authorize offensive actions against third parties.
B. It is legally protected under international self-defense doctrines for digital property.
C. It is acceptable if local law enforcement is notified within 24 hours of thecounter-attack.

D. It is ethically mandated to prevent further harm to the client's networkinfrastructure
Correct Answer: A

38.While assessing a logistics and shipping API, A network securityauditor runs a customized payload generator without verifying its impact, which inadvertently locks out all legitimate administrative users. Assessthe primary ethical failure in this scenario.

A. A breach of Non-repudiation, as the tool's execution logs were not preserved.

B. Failure to assess operational risk, directly violating the principle of Availability.

C. A violation of Confidentiality, as the system outage likely exposedunencrypted data.

D. There is no ethical failure, as uncovering deep vulnerabilities inherentlyrequires downtime.
Correct Answer: B

39.Upon discovering a severe flaw in a cloud storage provider, Anetwork security auditor contacts the organization and demands $50,000 in Ethereum before providing the vulnerability report. Evaluatethis action under ethical hacking laws.

A. It is ethically justified if the organization can easily afford the requestedcompensation.

B. This is an aggressive but legally recognized negotiation tactic within modern bug bounties.

C. This constitutes illegal extortion and is classified as malicious black-hat behavior.

D. It is valid under full disclosure guidelines as compensation for theresearcher's time.
Correct Answer: C

40.While assessing an online retail platform, A corporate security consultant runs a mass exploitation script without verifying its impact, which inadvertently crashes the primary production database. Assess the primary ethical failure in this scenario.

A. There is no ethical failure, as uncovering deep vulnerabilities inherentlyrequires downtime.

B. A violation of Confidentiality, as the system outage likely exposedunencrypted data.

C. Failure to assess operational risk, directly violating the principle of Availability.

D. A breach of Non-repudiation, as the tool's execution logs were not preserved.
Correct Answer: C

41. Following an engagement against a federal tax web portal, management strictly asks A freelance vulnerability assessor to falsifythe date of the test to meet a regulatory deadline in the final official report. Recommend the most ethical response.

A. Alter the report as requested, but leave a hidden cryptographic signatureindicating tampering.

B. Comply with the request, as the client owns the report and retains final editorial rights.

C. Agree to the modification, but charge a premium fee for alteringofficial compliance documents.

D. Refuse the request entirely to maintain the integrity, accuracy, andobjectivity of the audit.

Correct Answer: D

42.A bug bounty participant is offered a contract to audit a social mediastartup, but they recently is currently suing the company for wrongful termination. Judge the decision to accept this auditing contract.

A. Unethical due to a severe conflict of interest that compromises theauditor's objectivity.

B. Acceptable, as long as they only utilize automated scanning tools toremove bias.

C. Ethical, as their insider knowledge will result in a more thorough securitytest.

D. Legal and ethical, provided they sign a supplementary non-disclosureagreement.

Correct Answer: A

43.While officially authorized to test a logistics and shipping API, Asenior security researcher assumes the contract implicitly includes a third- party managed database physically located in the office and proceedsto attack it. Judge the legal validity of this assumption.

A. It is a valid assumption if both systems share the same internal IPsubnet. B. Ethically and legally dangerous; authorization must always be explicit, documented, and unambiguous.

C. It is standard practice to ensure no blind spots remain in the client'soverall audit.

D. It is legally permissible as long as the actor is a certified and licensedprofessional.

Correct Answer: B

44.A certified red teamer is hired to test a university's research database. During the engagement, they notice a physically separateHR network is highly vulnerable. The tester decides to deploy a ransomware simulator on it to provide a more comprehensive report. Evaluate this decision from a legal and ethical standpoint.

A. It is legally protected as long as the tester does not monetize or leakthefindings.

B. It is ethically sound because it improves the client's overall securityposture.

C. It is valid under standard ethical hacking frameworks provided nodataispermanently deleted.

It violates explicit authorization, risking severe legal liability andbreachingethical boundaries

Correct Answer: D

45.During a monitoring phase, A freelance vulnerability assessor detectsan active, malicious attack originating against a university's researchdatabase. They immediately respond by launching a DDoS attack against the attacker's IP. Judge this defensive response.

A. It is legally protected under international self-defense doctrines for digital property.

B. It is acceptable if local law enforcement is notified within 24 hours of thecounter-attack.

C. It is illegal vigilantism (hacking back); ethical hacking does not authorize offensive actions against third parties.

D. It is ethically mandated to prevent further harm to the client's networkinfrastructure.

Correct Answer: C

46.Following an engagement against a cloud storage provider, management strictly asks A network security auditor to change theroot cause from 'negligence' to 'advanced threat' in the final official report. Recommend the most ethical response.

A. Agree to the modification, but charge a premium fee for alteringofficial compliance documents.

B. Alter the report as requested, but leave a hidden cryptographic signatureindicating tampering.

C. Refuse the request entirely to maintain the integrity, accuracy, andobjectivity of the audit.

D. Comply with the request, as the client owns the report and retains final editorial rights.

Correct Answer: C

47. After discovering a critical flaw in a biometric authentication API, Afreelance vulnerability assessor reports it privately. The vendor ignoresthe report for 9 months. Frustrated, the researcher decides to uploadan automated exploitation script to GitHub. Critique this disclosure
strategy.

A. It is ethical as part of the Coordinated Disclosure framework sincethegrace period expired.

B. It is unethical as it maximizes risk to the public without providingaviablemitigation path.

C. It is legally acceptable because the vendor's silence automaticallywaivestheir copyright protections.

D. It is completely justified under the Full Disclosure model to force thevendor into action.

Correct Answer: B

48.A network security auditor is hired to test a social media startup. During the engagement, they notice a deactivated test environment ishighly vulnerable. The tester decides to create a new administrativeaccount on it to provide a more comprehensive report. Evaluate this decision from a legal and ethical standpoint.

A. It is valid under standard ethical hacking frameworks provided nodataispermanently deleted.

B. It violates explicit authorization, risking severe legal liability andbreachingethical boundaries.

C. It is ethically sound because it improves the client's overall securityposture.

It is legally protected as long as the tester does not monetize or leakthefindings

Correct Answer: B

49.Months after successfully finishing a penetration test on a regional hospital's network, An independent ethical hacker decides to retainacomplete dump of the customer database on a local home server 'just in case'. Critique this post-engagement practice.

A. It is legally required to prove the vulnerabilities existed in case of afutureaudit dispute.

B. It is ethically acceptable as long as the home server is disconnectedfromthe public internet.

C. It is a standard industry practice to retain client data for long-termhistorical benchmarking.

It blatantly violates the ethical mandate for secure data destructionand strict confidentiality

Correct Answer: D

50.A senior security researcher identifies a vulnerability in a publictransportation control system without any prior permission andanonymously submits the finding to a public bug tracker. Classify thehacker profile and evaluate the action.

A. White hat behavior; entirely ethical and legal since the ultimate goal wassystem defense.

B. Hacktivism; aimed at political reform by exposing the company's weaksecurity posture.

C. Black hat behavior; driven strictly by malicious intent and violationof theCIA triad.

D. Gray hat behavior; well-intentioned but legally perilous due to thestrict lack of authorization.

Correct Answer: D

Code of Conduct:

I _____ (Name / Reg No) certify that this submission is myoriginal work and that I have adhered to the guidelines specified for thisassessment.I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:

RUBRICS FOR CALCULATION:

Criteria	Weightage	y)
ConceptualUnderstanding	30%	De rat tho un dir an qu ac
Accuracy Answers	2	All an are
Applicationof Knowledge		Co ap co to -ba qu 2
Time Management	15%	Com esqu with effic

Criteria	We ge	Le (E			
Question Interpreta tion	10%	Int all qu co an res ap ate			